

SEE ALSO Newsletter of October 23, 2023

[doc. web n. 9941232]

Provision of September 28, 2023

Register of provisions

n. 426 of September 28, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN the meeting held today, attended by

Prof. Pasquale Stazione, President, Prof.

Ginevra Cerrina Feroni, Vice President, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Secretary General Fabio Mattei;

HAVING REGARD TO Regulation (EU) 2016/679 of the European

Parliament and of the Council, of April 27, 2016, concerning

the protection of natural persons with regard to the

processing of personal data, as well as the free

movement of such data and repealing Directive

95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing the

"Code regarding the protection of personal data",

which includes provisions for the adaptation

of the national legislation to Regulation (EU)

2016/679 of the European Parliament and of the Council, of

April 27, 2016, concerning the protection of

natural persons with regard to the processing of personal data,

as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter the "Code");

HAVING REGARD TO Legislative Decree No. 101 of August 10, 2018, containing

"Provisions for the adaptation of national legislation to the provisions of Regulation (EU)

2016/679 of the European Parliament and of the Council, of

April 27, 2016, concerning the protection of

natural persons with regard to the processing of personal data,

as well as the free movement of such data and repealing Directive 95/46/EC";

HAVING REGARD TO Regulation No. 1/2019 concerning

internal procedures of external relevance,

aimed at carrying out the tasks and

exercising the powers assigned to the Guarantor for the

protection of personal data, approved by

resolution No. 98 of 04/04/2019, published in

G.U. No. 106 of 08/05/2019 and on www.gpdp.it, doc. web

n. 9107633 (hereinafter "Guarantor Regulation No.

1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary

General pursuant to Article 15 of the Guarantor Regulation No. 1/2000 on the

organization and functioning of the office of the Guarantor for the

protection of personal data, doc. web n. 1098801;

Reporting by Dr. Agostino Ghiglia;

WHEREAS

1. The violation of personal data and the requests

of the data subjects

On XX, ASL Napoli 3 Sud (hereinafter "Company")

notified the Authority, pursuant to Article 33 of the

Regulation, of a personal data breach - subsequently supplemented with notes from XX and XX, XX and XX - concerning a cyber attack caused by ransomware malware, on its information systems.

Considering the high number of data subjects involved and the nature of the personal data subject to the breach, the Office requested information from the Company regarding the aforementioned personal data breach, in order to acquire, in particular, elements on both the technical and organizational measures adopted regarding the IT authentication procedures for VPN access and workstations, which were in place at the time of the breach, as well as the status of progress of the interventions for the adoption of suitable measures to prevent similar future breaches (note of XX). In response to this request, the Company provided feedback, with note of XX, stating that:

- "from an analysis of the documentation in the possession of ASL Napoli 3 Sud, related to the privacy incident that occurred and notified on XX, (...) there are no correlations regarding the credentials and accounts compromised in this event and the credentials subject to data leak in the data breach of XX";
- "in relation to the findings related to the privacy incident of XX concerning the 'stolen credentials published on the dark web to gain fraudulent access to VPN', we provide (...) a summary table of the correlations between the Incident Report 'Executive & Technical Report — Sabbath Ransomware Security Incident' of XX, (...) and the investigations conducted by the IOC in the black market reported in the report 'XX'";
- "the Company's ICT unit has adopted the 'Regulation for the use of the company's IT and telematic system' containing in Articles 13 and 31, respectively, the indication of the characteristics of passwords and the indication for access to the Virtual Private Network (VPN). Specifically, at the time of the breach, the IT authentication procedures used for VPN access and workstations did not require the use of two-factor authentication, while the password policy did not include a differentiation between accounts with administrative privileges and accounts without administrative privileges. In particular, passwords were created by the IT service defined with active directory according to characteristics that required: the creation of passwords with at least 8 characters, automatic expiration after XX from issuance, and the presence in the key of uppercase letters, lowercase letters, and numbers. It is worth noting that, currently, following participation in the tender on MePA portal No. 2006825, as of the final notification of the privacy incident that occurred, the entity has effectively adopted multi-factor authentication for VPN connections

'implemented with the perimeter Firewall XX with two factor authentication (XX)'.
the ability to access the internal network of the Company, utilizing the previously established access points" (see notification of XX).

2.2. Consequences of the Data Breach

The consequences of the data breach have been assessed as follows:

- "The attack has led to the encryption of sensitive data, including personal data of patients and employees, which has raised significant concerns regarding compliance with data protection regulations."
- "The Company has initiated a thorough investigation to determine the extent of the data compromised and to implement measures to mitigate the impact on affected individuals."
- "Notifications to affected individuals are being prepared in accordance with the requirements set forth in the applicable data protection legislation."

3. Measures Taken

3.1. Immediate Actions

In response to the data breach, the Company has taken the following immediate actions:

- "Engaged cybersecurity experts to assist in the investigation and recovery process."
- "Implemented additional security measures to prevent further unauthorized access, including the enhancement of network monitoring and the strengthening of access controls."
- "Conducted training sessions for employees to raise awareness about cybersecurity threats and best practices for data protection."

3.2. Long-term Strategies

The Company is committed to enhancing its data protection framework through the following long-term strategies:

- "Regular audits of IT systems and data protection policies to ensure compliance with legal requirements and industry standards."
- "Investment in advanced cybersecurity technologies to detect and respond to threats in real-time."
- "Establishment of a dedicated data protection officer role to oversee compliance and data protection initiatives."

4. Conclusion

The Company acknowledges the seriousness of the data breach and is fully committed to addressing the situation with transparency and diligence. Ongoing communication with the relevant authorities and affected individuals will be maintained to ensure that all necessary steps are taken to rectify the situation and prevent future occurrences.

access through the VPN channel preparing the internal network for a destructive attack. On the morning of XX, the ransomware Arcane.exe (Sabbath) was initiated, encrypting multiple files and documents. Following the encryption activity, the IT operators of the Company noticed the change in the extension of the files residing on the disk of their assets and a ransom letter (...) (see notification of XX);

- that "the services that experienced only a partial interruption were identified concerning the following items: (i) employee salaries; (ii) acquisition and payment of supplier invoices and reimbursements. It is specified that the provision of services to users and the delivery of healthcare services was carried out continuously without suffering interruptions of any kind" (see notification of XX).

2.1.2. Inspection Activities

During the inspection activities, the Company, regarding the methods and timing of the attack, also "confirmed the [...] timeline [present in report XX] and reported that forensic analyses reconstructed the breach starting from the first unauthorized accesses, on XX, from a foreign IP, via VPN, using the credentials of non-technical personnel of the ASL, available on the dark web. These credentials were then used to obtain administrator privileges. Subsequently, after a silent phase, the attacker proceeded to install and distribute the malware, and in the month of XX, the credentials of domain administrators were compromised, and encryption was launched on the Hypervisor of the VMDK (physical files of

virtual machines). The incident was, therefore, detected on the morning of XX by a healthcare operator who, noticing a malfunction of the application (IL), contacted the on-call person from the IT systems who, following specific checks, found the modification of the domain administrator credentials and raised the alarm.” On the same occasion, the Company declared that “on the morning of XX [it was] found, accessing a locked server, the ransom request message from the attackers,” that “the data exfiltration presumably occurred between XX and XX” and “that the breach did not involve the clinical engineering applications in the individual facilities (e.g., CT, MRI, monitors) nor the RIS-PACS instrumentation of the facilities, while all corporate applications served by the data center were blocked, including the ADT systems which were prioritized for restoration” (see minutes of XX, pages 3 and 4).

2.2. Measures in Place at the Time of the Breach

2.2.1. Notification of the Breach to the Authority

With reference to the measures in place at the time of the breach, in the context of the notification and subsequent integrations, the Company stated that “the corporate IT system is based on an XX domain for all on-premise healthcare and administrative accounting software applications and an XX domain for the management XX of corporate email, Office Automation, website, and PEC XX. The corporate LAN network extends throughout the ASL's area of competence through an SPC contract in agreement with Consip with the supplier Fastweb. The following security tools have been provided:

- a. External access via VPN Firewall XX
- b. Perimeter Firewalls XX for controlling I/O traffic managed by Fastweb through a CONSIP contract
- c. Proxy XX for connecting clients as the only access to the internet with restrictions on access to legally/organizationally unauthorized sites, limitations on advertising flows and pop-ups
- d. Firewall Systems XX for monitoring network traffic for I/O with SSL Inspection for Email (XX) packets
- e. Antivirus/Antimalware XX on Servers and clients supported by additional monitoring software XX (XX) for behavioral management
- f. Monitoring System XX for managing, virtual patching, and securing the electromedical equipment present in the company (currently in free trial)
- g. Privacy data breach policy with related attachments” (see notifications of XX and XX).

Further elements on this point were provided by the Company with the above-mentioned note of XX, sent in response to a specific request for information from the Office (note of XX) regarding the authentication procedures used in the context of VPN access and the workstations in place at the time of the breach and the password policies provided for the different types of users (see paragraph 1 of this provision).

2.2.2. Inspection Activities

During the inspection activities, the Company also clarified that “the users who used the VPN were about 1200, that a multi-factor authentication procedure was not provided, and that authentication was carried out using domain credentials [...]”, that “the credentials attributable to general practitioners (MMG) were recorded in Active Directory in a specific group for which interactive logon was prevented, allowing only the use of a specific application dedicated to the same MMG exposed in VPN”, that “at the time of the incident of XX, a different password policy was provided for the administrator system users of the servers (XX)”, that “at the time of the incident of XX, the password history mechanism to prevent password reuse was not active” (see minutes of XX, page 3).

Regarding the technical and organizational measures adopted to ensure the availability and resilience of the processing systems and services, as well as the timely restoration of the availability and access to personal data in the event of an incident, the Company, during the same activities

****2.3. Measures Adopted Following the Breach****

****2.3.1. Notification of the Breach to the Authority****

With reference to the measures adopted following the breach, the Company, in the context of the notification of the breach made pursuant to Article 33 of the Regulation, represented that:

- “Connections and communications from the outside were isolated in order to interrupt the possible propagation of the malware. An investigation was initiated aimed at analyzing the incident and its

causes in order to achieve the remediation of the systems. It is intended to immediately proceed with the creation of a parallel infrastructure for the restoration of essential activities as well" (note of XX);

- "The observed effects highlighted a scenario in which several critical ICT systems and services were suspended. The IT department of the ASL, including the event, initiated the most immediate containment actions, including: isolation of the infrastructure and ICT services, rendering them temporarily unavailable; interruption of all IT services regardless of their positioning, to prevent the propagation of the infection. The attack created a limited disruption in the provision of critical services to end users as the website, email, and other services were hosted by third parties; involvement of partners and stakeholders and activation of a crisis unit in order to identify containment and definitive removal actions for the threat. Among the various immediate actions, the following are noted:

- initiation of cyber threat hunting activities;
- initiation of appropriate analyses in the field of Cyber Threat Intelligence to support Response activities;
- initiation of recovery activities for the compromised infrastructure through the creation of a new zone called the green zone;
- creation of a [multidisciplinary] task force dedicated to assessing the sensitivity of the data subject to publication on the attacker's portal" (note of XX).

With the aforementioned note of XX, the Company further represented that, "with an express request directed to the provider Fastweb S.p.A., it intended to request specific analysis activities of the malfunction aimed at identifying the causes and effects of the data breach. A specific assignment was entrusted to Leonardo S.p.A. for the analysis of the incident in Second Opinion and drafting of reports aimed at specific remediation activities, as well as for the reconfiguration and updating of the disaster recovery plan to ensure business continuity, as well as the preparation of all appropriate technical and organizational measures aimed at monitoring, controlling, and preventing the technological and corporate security perimeter. Furthermore, new dedicated VPN connections with dual authentication were activated to securely access the company's IT structure in order to carry out verification and analysis activities on the systems, which are still ongoing. ASL Napoli 3 Sud, having completed the first critical phase of containment of the cyber incident, through activities of designing the Green Zone, crisis management, and intelligence security assessment, intends, with the support of the provider Leonardo S.p.A., to proceed with the implementation of the following tools, policies, and services in order to prevent similar future breaches and eliminate any remaining vulnerabilities in the security system:

- Restoration of services with Application Security Testing, VA, PT activities;
- Tuning services XDR, RTSM+IH, TIS, Basket Crisis Management & Incident Response;
- Design of a System for applications;
- Activities of Threat Intelligence System (Early Warning, Data Loss Prevention, Brand Abuse, Anti-Phishing with takedown);
- On-premise specialist support with TAM resources, CERT with cyber skills;
- Policy Enforcement, Awareness, Phishing Campaign, Data Rescue.

Following the implementation of these services, to be considered a High Priority, the adoption of the additional services listed below will follow: Unified End-Point Management UEM/MDM; DNS Secure; Verification analysis of the backup system, Anti DDoS, NACS - Secure mail system; FNCS Assessment; Attack simulation and resilience testing – Cyber Exercise. In addition to the aforementioned technical activities and services, the implementation of an Information Security Management System (ISMS) is included, as well as a training service with the provision of an asynchronous FAD platform on Information Security for all employees of ASL Napoli 3 Sud."

****2.3.2. Inspection Activities****

During the inspection activities, with reference to the data and systems recovery operations, the Company stated that "a recovery plan for the systems has been defined thanks to the presence of backups" (minutes of XX, p. 4) and that "the remediation, recovery, and restoration actions activated immediately after the forensic copies were made have led to the availability of the first...

****systems (CACOMM and AREAS) on the XX and, subsequently, the others until the beginning of XX, also based on the aforementioned proposal. At the same time, the remediation, recovery, and restoration of the workstations were carried out**** (minutes of XX, p. 2).

****2.4. Notification of the violation to the interested parties****

In relation to the notification of the violation to the interested parties, the Company initially represented that “the interested parties were informed through a communication published on the institutional website” (see notification of XX) and, subsequently, that such communication would be made “by XX” attaching also the “sample of the communication pursuant to art. 34 GDPR to be sent to approximately 67,000 interested parties involved in the violation” (see notification of XX).

Finally, the Company declared that “the risk for the interested parties must be considered high and, therefore, it is necessary to proceed with the communications to the interested parties pursuant to art. 34 GDPR. Given that a communication ad personam has already been prepared for 70,891 interested parties through the company Mavasoftware s.r.l.s., specifically appointed pursuant to art. 28 GDPR, or by email communication in the case of employees; for the remaining large number of interested parties, it must be considered what has already been stated in Section F, p. 7 (Description of the Violation) in terms of costs and disproportionate effort pursuant to art. 34, par. 3, lett. c) GDPR, as already described and anticipated through the PEC communication sent to this Authority on XX. For these reasons, (...) the undersigned Company intended to proceed with general informative communications to the users” and that “it necessarily had to manage and adopt two distinct methods of communication to the interested parties, intrinsically linked to the characteristics of the two datasets and their different moments of analysis and evaluation [...] for a complete view of the management of communications, the schematic division of the management of communications to the interested parties pursuant to art. 34 GDPR in relation to the peculiarities of the two datasets managed by this company is reported: 70,738 interested patients/users reached by ad personam communication via registered mail with return receipt, with the service entrusted to the data processor pursuant to art. 28 GDPR MAVASOFT srls; 153 interested employees reached by ad personam communication via corporate email service, personal email, or registered mail XX interested patients/users, through general communication (...)” (see notification of XX).

****3. Assessments of the Department on the processing carried out and notification of the violation referred to in art. 166, paragraph 5 of the Code****

Regarding the described case, the Office, based on what was represented by the data controller in the notification of the violation and what emerged during the inspection activity, as well as subsequent assessments, notified the Company, pursuant to art. 166, paragraph 5, of the Code, the initiation of a procedure for the adoption of the measures referred to in art. 58, par. 2, of the Regulation, inviting the aforementioned data controller to produce defensive writings or documents or to request to be heard by the Authority (art. 166, paragraphs 6 and 7, of the Code; as well as art. 18, paragraph 1, of law no. 689 of 24/11/1981). In particular, with act no. XX of XX, which must be understood as fully reproduced here, the Authority considered that the Company processed the personal data in question in violation of the principles of “integrity and confidentiality,” as per art. 5, par. 1, lett. f), of the “data protection by design” referred to in art. 25, par. 1, of the Regulation, as well as the obligations regarding security, as per art. 32 of the Regulation.

The Company submitted its defensive memoranda, pursuant to art. 166, paragraph 6, of the Code, without requesting to be heard by the Authority. In particular, with a note of XX, it declared that: “the violation resulted in a loss of confidentiality and availability of the data. The dual nature of the violation is likely articulated in two distinct phases: (i) the loss of confidentiality can be observed at the moment when the attackers actually accessed the ASL’s IT systems, as well as at the moment when they proceeded with the exfiltration of the identified dataset; (ii) the loss of availability, on the contrary, occurred at the moment of the exploit of the attack through the ‘launch’ of the CobaltStrike program for the encryption of the ASL’s information systems”; “regarding the severity of the violation, it was not possible to consider it anything other than high. In fact, due to the number and type of interested parties involved, as well as the volume and types of personal data impacted, it could not potentially be considered from the outset as having a high probability of causing harmful consequences for the rights

and freedoms of the interested parties. Consequences that (...), however, do not seem to have materialized into actual and verifiable harm for the interested parties”; “as for the duration of the violation, it is necessary to appropriately distinguish the moment of the exploit of the attack from what emerged from the cyber threat intelligence activities carried out by Leonardo S.p.A. in the context of the assignment regarding the privacy incident. In fact, (...), the first moment in which traces of access to the ASL's IT systems were detected would date back to XX, at which point the silent scouting activity that would lead to the launch of the malicious software on XX would have started. In a perspective of intellectual coherence, the violation, although it effectively sees its consumptive moment precisely the data e contenuti sensibili”;

“in conclusione, si evidenzia che l'Azienda ha attuato tutte le misure necessarie per contenere e mitigare gli effetti della violazione, dimostrando un impegno costante nella protezione dei dati e nella sicurezza informatica. Le azioni intraprese hanno consentito di ripristinare i servizi e di garantire la continuità operativa, nonostante le difficoltà iniziali. Si conferma, pertanto, che l'Azienda ha operato in buona fede e con la massima diligenza per affrontare la situazione emergenziale, collaborando attivamente con le autorità competenti e i fornitori per risolvere l'incidente e prevenire futuri eventi simili”;

“si rimanda, infine, a ulteriori approfondimenti e relazioni tecniche che saranno predisposte dalla Task Force multidisciplinare, al fine di fornire un quadro completo e dettagliato delle misure adottate e delle strategie future per migliorare la sicurezza dei sistemi informatici dell'Azienda”.

****Confidentiality****, while the remediation activity and the creation of the so-called Green Zone, in conjunction with the recovery, through the company's backup systems in use, of the data existing prior to the attack, have allowed for the continued provision, even alternatively, of services in favor of patients/users and employees of the Company, limiting the loss of availability;

*******“These factual elements cannot be overlooked, in the excitement of the moments following the attack, when evaluating an activity that has reduced the possible negative effects on the affected parties. As further evidence of this, also in order to fully comply with the informational obligations towards the affected parties, the Company established the ASL Napoli 3 Sud Data Breach Multidisciplinary Task Force with Note prot. em. n. XX of XX, later formalized with a specific Resolution n. XX of XX. The considerable work of the Task Force focused on the analysis of the data set subject to exfiltration (approximately 3 GB divided into about 4000 files) in order to meticulously identify the number and types of affected parties, as well as the volume and categories of personal data. This activity was characterized by necessity and urgency as it was intrinsically connected to the identification of all useful elements to provide increasingly updated and accurate information to the Supervisory Authority and Judicial Authority and to ensure communications to the affected parties pursuant to Article 34 of the GDPR. On this last point, the activity carried out by the Company cannot be underestimated, which, from the very first moment, had among its main objectives the guarantee and non-infringement of the right to information of the affected parties through the fundamental operations of the Task Force that successfully led to the identification of all subjects impacted by the breach, subsequently seeking the best and most efficient ways to reach them, not without a significant commitment for the Administration” considering that “for the forwarding of communications to the

affected parties, costs of approximately €300,000.00 were incurred, in order to reach about 66,627 affected parties, through the assignment to Mavasoftware s.r.l.s.”;

***“The purchase of additional services aimed at remedying the issues that emerged and enhancing the security posture (referring to assignments to Leonardo S.p.A., Mavasoftware S.r.l.s., Covisian S.p.A., etc.)” and “the economic commitment undertaken by the Company to mitigate the effects of the breach, especially in the primary interest of the users, is evident”;

***“Following the incident that occurred and for more than a year now, the ASL has embarked on a virtuous path aimed at enhancing the corporate security infrastructure as well as increasing the human and technological resources available to the UOC ICT; in fact, a total of 6 staff members have been hired, including 4 at the managerial level, 1 officer, and 1 technical-informatic assistant”;

***“Also thanks to the support of external suppliers, the Company has completed the following technological implementations:

- **Incident response and crisis management activities, including investigations and in-depth analyses aimed at identifying the dynamics associated with the incident and defining appropriate containment and threat response actions;
- **Vulnerability Assessment activities aimed at the dynamic verification of the security of network devices, in order to identify any vulnerabilities, incorrect security configurations, and deficiencies in active protection levels that could expose the Company to internal and external attacks;
- **Design and planning of the Green Zone infrastructure where all sensitive applications pertaining to the Company have been migrated, as part of the security measures consolidation program undertaken by the Administration;
- **Continuous monitoring of security events, through the supplier Leonardo S.p.A., also in light of the increasing cyber threats to organizations. In fact, it has become essential to review the approach to risk management and identify strategies to reduce the vulnerability of IT infrastructures. In this context, the present continuous monitoring activity has been carried out through a SOC 24/7, 365 days a year, composed of a team of specialists (analysts, system engineers, security testers, and malware specialists);
- **The Security Information and Event Management (SIEM) platform present at Leonardo's infrastructures is utilized, with additional remote Incident Handling activities. In support of this activity, there are 2 fixed presences from Leonardo on-site and 1 remote coordinator for the management of anomalies/cyber threats, reported through the real-time monitoring service, with direct interaction with the Leonardo SOC, responsible for defining the activities for managing anomalies. This activity of the on-site resources has been carried out in collaboration with the personnel of the undersigned Company, in order to facilitate the interaction of internal staff on the processes of managing security incidents and the technologies in use;
- **Specialized support from the supplier for tuning the continuous monitoring service, aimed at supporting the Company in executing this activity on the service delivery platforms;
- **Device management activities, aimed at continuously managing and monitoring perimeter protection platforms and the centralized EDR management platform;
- **Implementation of the improved Managed Detection & Response (MDR) service aimed at (i) to minimize possible exposure windows to potential cyber attacks for endpoints within the perimeter; (ii) to carry out automatic remediation activities for incidents recognized as “true positives” and of maximum criticality; (iii) to protect endpoints even in the temporary absence of an Internet connection; (iv) to allow the possibility of isolating a compromised endpoint from the network while retaining control from the cloud platform; and finally, (v) to protect in real-time against known and unknown attacks that utilize known methodologies and/or indicators;
- Policy Review activities, i.e., conducting analysis of perimeter flows (inbound and outbound) for a quick and effective assessment of the compliance status of the complex firewall structure;
- Cyber Threat Intelligence, Early Warning Data Breach, brand abuse, and anti-phishing with takedown;

- design of a system for application security (Web Application Firewall) and perimeter protection systems for peripheral sites (Next Generation Firewall);
- Cyber Security Awareness for operational workforce; this activity aims to propose training content that, through storytelling techniques, aims to provide all Company personnel with knowledge of concepts and best practices related to cybersecurity, with the ultimate goal of mitigating the structure's exposure to threats that leverage the human factor;
- simulated Phishing campaigns for all Company personnel using specific tools provided by the supplier. This action aims to assess the level of exposure of the Administration to threats conveyed via email and to increase personnel awareness and, therefore, the robustness of the entire Company;

"It is appropriate to highlight the constant and high degree of cooperation that the Company has maintained with the Data Protection Authority since the very first moment it became aware of the occurrence of the incident in question," emphasizing "the frequency with which the undersigned Company has sought to ensure an adequate flow of information regarding all evidence obtained in relation to the criminal activity suffered. In fact, pursuant to Article 33 of the GDPR, the Company proceeded on XX to the preliminary notification, within the terms established by law, followed by subsequent supplements on XX and XX, XX, and finally, the concluding one on XX;" "the informative activity did not end in mere scheduled compliance, but rather in a dynamic, constant, collaborative, and proactive activity aimed at correctly undertaking all necessary steps for the resolution of the incident and for the support of those indirectly involved in the hacker attack;"

"the undersigned Company, in its communication to the interested parties, aimed to take care of every single aspect in order to effectively reach all interested parties, even potentially, involved in the violation;"

"the Company has (...) responded within the legal terms to the request for additional information pursuant to Article 157 of Legislative Decree No. 196/2003, received on XX. Finally, the clearest element in a collaborative sense with the Authority is undoubtedly represented by the support provided to it during the inspection activities carried out pursuant to Article 58, paragraph 1, letters a), e), and f), of the GDPR and Articles 157 and 158 of Legislative Decree No. 196/2003, as well as pursuant to Articles 21 and 22 of Regulation No. 1/2019 of the Data Protection Authority, conducted at the headquarters in Castellammare di Stabia (NA) - C.so Alcide De Gaspari No. 167, on the days of XX, XX, and XX;"

"the aforementioned activity involved both the company components (specifically UOC ICT and the Privacy Office, supported by the Data Protection Officer) and the external components that participated in various capacities in the management of the privacy incident in question. Indeed, on all three days, the Authority had the opportunity to "see firsthand" the commitment and concrete progress that the Company has made both to mitigate the harmful effects of the incident and to prevent and minimize the risk that similar situations may occur again. Specifically, timely responses were provided to the requests made by the Officials during the auditing, also through the support of presentations and documentary productions attached to the minutes drawn up on-site;"

"with the support of the substantial documentation already in the possession of this esteemed Authority, it is evident how the Company has provided maximum support and cooperation in acquiring as many instructive elements as possible useful for the precise delimitation of the fact and for the correct determination of the consequences and impacts on personal data and on the rights and freedoms of the interested parties;"

"(...), the categories of personal data impacted by the violation, concerning users and patients are (i) identifying personal data (surname and name, tax code, phone number, email address) and (ii) health-related data pursuant to Article 9 of the GDPR (medical appointment bookings with indications of suspected diagnosis, Covid test results, vaccination data). As for employees, the detailed categories of personal data impacted are (i) personnel activities (employee shifts, performance sheets, attendance records); (ii) accounting documentation of personnel (bank data and electronic invoices);

(iii) personal identification documents and (iv) reports/certifications;”

“the Company has not adhered, nor does it currently adhere, to any code of conduct pursuant to Article 40 of the GDPR. However, it is represented that the undertaken activity...”

Company aimed at the implementation of an Information Security Management System (I.S.M.S.). This circumstance is well highlighted by the substantial activity already carried out by the undersigned Company following the violation concerning information security, which led to the completion of 5 training days provided for the appointed Company Representatives for Information Security and the availability, for all company personnel, of an e-learning platform on the subject in question, with the detection of the level of awareness achieved by the learners. Furthermore, in collaboration with contracted partners, specific policies on security have been adopted. Finally, the Company has adopted a document expressing its internal and external context, in addition to the risk assessment document specifically prepared for information security.

It is necessary to highlight (...) how the Company, following the evident exploit of XX, reacted promptly, continuously guaranteeing all healthcare and administrative-health services to patients/users and also successfully working on the preparation of alternative channels to the official ones to ensure services for employees, which continued regularly.

Additionally, it should be noted that the contested violation does not seem to have had significant repercussions in terms of its effects, as, despite the wide range of publicity and the availability of information channels specifically prepared for users (specifically, the email box XX and the related toll-free number), no significant contacts, complaints, appeals, and/or formal notices have been received from them. (...) It must also be taken into consideration that the criminal activity occurred during one of the most critical historical moments for global health, due to the spread of the SARS-CoV-2 virus infection. In fact, the enormous impact that the pandemic has had on the life of the population and on the actions of Public Administrations in the healthcare field must be acknowledged, which were put to the test by a health emergency of such magnitude that for the first time they were forced to face numerous difficulties both operationally and managerially, as well as in terms of expenditure. The rapid spread of the pandemic also forced healthcare companies worldwide to a sudden change in the organization of daily work activities, generally introducing new tools (e.g., VPN) to allow, on one hand, the possibility of smart and remote working, and, on the other hand, enabling the seamless execution of tasks for the very high number of individuals impacted by the virus. Ultimately, it is worth highlighting in this context that during the pandemic, although it was the intention of this Company, even during the incident, to continue with the planned security implementation paths (for example, MFA with segregation and segmentation profiles of networks), such intent proved to be scarcely feasible in the short term. This is due to the fact that the aforementioned operations would have involved, due to the necessary replacement and processing of all corporate domain accounts, the interruption of fundamental services within the scope of continuity of care, thus drawing attention to the evident difficulty arising from a completely exceptional, unpredictable, and unprecedented emergency situation that was attempted to be remedied with a prompt and resilient spirit...

4. Outcome of the investigative activity

Taking note of what has been represented by the Company during the proceedings, it is observed that:

- **For "personal data," it is meant "any information relating to an identified or identifiable natural person ('data subject')" and for "data relating to health," "personal data concerning the physical or mental health of a natural person, including the provision of health care, which reveals information about their health status" (art. 4, par. 1, nn. 1 and 15 of the Regulation). Recital 35 of the Regulation further specifies that health data "includes information about the natural person collected during their registration to receive health care services"; "a number, symbol, or specific element assigned to a natural person to uniquely identify them for health purposes." These latter data deserve greater protection since the context of their processing could create significant risks to fundamental rights and freedoms (Recital 51 of the Regulation);**

- **The data controller is, in any case, required to comply with the principles regarding data protection, among which is the principle of "integrity and confidentiality," according to which personal data must be "processed in a manner that ensures adequate security (...), including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage" (art. 5, par. 1, lett. f) of the Regulation);**

- **In terms of security of processing, the data controller and the data processor, "taking into account the state of the art and the costs of implementation, as well as the nature, scope, context, and purposes of processing, as well as the risk of varying probability and severity for the rights and freedoms of natural persons (...) implement appropriate technical and organizational measures to ensure a level of security... **

situation, and the purposes of the processing, as well as the risks with varying probabilities and severities for the rights and freedoms of natural persons posed by the processing, both at the time of determining the means of processing and at the time of the processing itself, the data controller [must implement] appropriate technical and organizational measures, such as pseudonymization, aimed at effectively implementing the principles of data protection, such as minimization, and integrating the necessary safeguards into the processing to meet the requirements of this regulation and protect the rights of data subjects" (see also Recital No. 75 of the Regulation);

according to Recital No. 78 of the Regulation, the data controller should adopt internal policies and implement measures that meet the aforementioned principle. According to the "Guidelines 4/2019 on Article 25 - Data Protection by Design and by Default" adopted by the European Data Protection Board on XX, the aforementioned Recital "suggests a responsibility for controllers, namely to continuously assess whether they are using, at any given time, the appropriate means of processing and whether the measures chosen effectively counter existing vulnerabilities. Furthermore, controllers should conduct periodic reviews of the security measures in place to safeguard and protect personal data, as well as the procedure for managing data breaches."

"The obligation to maintain, verify, and update, where necessary, the processing also applies to pre-existing systems. This implies that systems designed before the entry into force of the Regulation must be subjected to checks and maintenance to ensure the application of measures and safeguards that effectively implement the principles and rights of data subjects" (see especially points Nos. 7, 38, 39, and 84);

with particular reference to the main elements of design and default settings, related to integrity and confidentiality, the controller must:

1. assess the risks to the security of personal data, considering the impact on the rights and freedoms of data subjects, and effectively counter those identified;
2. take security requirements into account as early as possible in the design and development of the system, continuously integrating and conducting relevant testing;
3. define the processing of data in such a way that a minimum number of people need to access personal data to perform their functions, and limit access accordingly;
4. protect personal data from unauthorized and accidental alteration and access, both during their transfer and during their storage;
5. record relevant events for information security purposes and monitor them to promptly detect any security incidents (see the aforementioned "Guidelines 4/2019 on Article 25", especially point No. 85).

The "Guidelines 9/2022 on the Notification of Personal Data Breaches under the GDPR" adopted by the European Data Protection Board on March 28, 2023 (https://edpb.europa.eu/system/files/2023-04/edpb_guidelines_202209_personal_data_breach_notification_v) clarify that "the ability to identify, process, and report a breach in a timely manner must be considered an essential aspect" of the technical and organizational measures that the controller and the processor must implement, pursuant to Article 32 of the Regulation, to ensure an adequate level of security for personal data (point No. 41).

In this regard, Recital No. 85 further clarifies that “a personal data breach may, if not adequately and promptly addressed, result in physical, material, or immaterial harm to individuals, such as loss of control over their personal data or limitation of their rights, discrimination, theft or identity fraud, financial losses, unauthorized deciphering of pseudonymization, damage to reputation, loss of confidentiality of personal data protected by professional secrecy or...

any other significant economic or social damage to the affected individual.” Similarly, according to Recital No. 87, “it is appropriate to verify whether all adequate technological and organizational protective measures have been implemented to immediately determine if there has been a breach of personal data and to promptly inform the supervisory authority and the data subject. It is important to establish that the notification has been transmitted without undue delay, taking into particular account the nature and severity of the personal data breach and its consequences and negative effects for the data subject.”

5. Assessments of the Authority and Conclusions.

In light of the above, it is noted that the processing carried out in the context examined requires the adoption of the highest security standards in order not to compromise the confidentiality, integrity, and availability of personal data of millions of data subjects. This also takes into account the purposes of the processing and the nature of the personal data processed, which also belongs to special categories. On this basis, the security obligations imposed by the Regulation require the adoption of rigorous technical and organizational measures, including, in addition to those expressly identified in Article 32, paragraph 1, letters a) to d), all those necessary to mitigate the risks presented by the processing.

In light of the assessments mentioned above, considering the statements made by the data controller during the investigation and noting that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Authority, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code “Falsehood in declarations to the Authority and interruption of the execution of the tasks or exercise of the powers of the Authority,” the elements provided by the data controller in the above-mentioned defense memorandum, although deserving of consideration, do not allow for overcoming the observations notified by the Office with the aforementioned initiation act of the procedure, nor do any of the cases provided for by Article 11 of the Regulation of the Authority No. 1/2019 apply.

From the examination of the information and elements acquired as well as the documentation provided by the Company, it emerged that the processing was carried out in violation of Articles 5, paragraph 1, letter f), 25, and 32 of the Regulation, in relation to the following profiles:

5.1. Failure to adopt adequate measures to promptly detect the breach of personal data

During the investigation, it emerged that “the reconstruction of events places the potential first access of the attacker to the VPN of ASL Napoli 3 SUD approximately at XX hours on XX, coinciding with the start of an internal scanning activity of the Remote Desktop service and anomalous RDP access events to strategic assets,” and that malicious actors carried out a series of preparatory operations for the cyber attack, following which “alerts generated by the security apparatus XX” were produced, from which “evident anomalous signals emerged showing a significant increase in scans and suspicious behaviors in the days leading up to the VPN access of the malicious actor,” particularly from XX, “further anomalous administrative authentications were recorded during the evening hours of XX, from a system with IP address XX,” as well as on XX “multiple alarms related to suspicious commands and enumeration activities, executed using the SMB protocol, coinciding with the VPN access by the attacker, using the account XX” (see pages 12 and 13, 16 - 18 of report XX).

The Company stated that “the data exfiltration presumably occurred between XX and XX and that the logging systems did not detect all outgoing traffic from the Company’s workstations but only the main events,” that “the incident was [...] detected on the morning of XX by a healthcare operator who, upon noticing a malfunction of the application (IL), contacted the on-call person from the IT systems who, following specific checks, found the modification of the domain administrator credentials and raised the alarm.” In particular, the Company stated that at the time of the cyber attack “it had a firewall XX for

perimeter defense which was not monitored 24/7, a firewall XX for internal defense, as well as agent XX (XX) which, at the time of the incident on XX, was in the process of roll-out, that is, not installed on all machines, for internal monitoring for deep defense. Therefore, there was no structured organization for the daily reading and analysis of logs” and “it had very limited technological and human resources” (see minutes of XX p. 4, XX p. 4, and of XX, p. 2).

From the above, an inadequate management of the aforementioned alerts emerged, which did not allow the Company to promptly become aware of the personal data breach that occurred. Therefore, the failure to adopt adequate measures to promptly detect the personal data breach was found not to be in compliance with the provisions of Article 5, paragraph 1, letter f), and Article 32, paragraph 1, of the Regulation which, taking into account what is provided by the aforementioned “Guidelines 9/2022 on the notification of personal data breaches under the GDPR,” requires that the data controller and the data processor must implement measures to “identify [...] a breach promptly” (point No. 41).

5.2. Failure to adopt adequate measures to ensure the security of networks

6. Adoption of the injunction order for the application of the administrative monetary penalty and accessory sanctions (Articles 58, paragraph 2, letter i and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The violation of Articles 5, paragraph 1, letter f), 25, paragraph 1, and 32 of the Regulation, caused by the conduct of the Company, is subject to the application of the administrative monetary penalty pursuant to Article 83, paragraphs 4 and 5 of the Regulation.

It should be noted that the Authority, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to “impose an administrative monetary penalty pursuant to Article 83, in addition to [other] corrective measures [referred to in this paragraph], or in lieu of such measures, depending on the circumstances of each case.”

****Single Case**** and, in this context, “the College [of the Authority] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Authority's website pursuant to Article 166, paragraph 7, of the Code” (Article 16, paragraph 1, of the Authority's Regulation No. 1/2019).

The aforementioned monetary administrative sanction imposed, depending on the circumstances of each single case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation, in light of the elements provided in Article 83, paragraph 2, of the Regulation in relation to which, for the cases in question, it is observed that:

1. The Authority became aware of the event following the notification of a personal data breach made by the data controller and from several reports received by the Authority regarding the incident (Article 83, paragraph 2, letter h of the Regulation);
2. The data processing carried out by the Company involved data capable of revealing information about the health of a very significant number of data subjects (Article 83, paragraph 2, letters a) and g) of the Regulation);
3. The data controller did not exhibit any intentional behavior, as the episode appears to have been caused by fraudulent behavior on the part of a third party, formally reported to the postal police (Article 83, paragraph 2, letters a) and b) of the Regulation);
4. The Company addressed the issue by introducing, after the occurrence of the event, a diversified series of measures aimed not only at mitigating the damage suffered by the data subjects but also at reducing the replicability of the event itself (Article 83, paragraph 2, letter c) of the Regulation);
5. The data controller, from the outset, demonstrated a very high degree of cooperation with the Authority at every stage of the investigation, including the inspection phase (Article 83, paragraph 2, letter f) of the Regulation).

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the monetary sanction provided for by Article 83, paragraphs 4 and 5 of the Regulation, in the amount of €30,000.00 (thirty thousand) for the violation of Articles 5, paragraph 1, letter f), 25,

and 32 of the Regulation, as an administrative monetary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and deterrent.

It is also considered that the accessory sanction of publication on the Authority's website of this provision, as provided for by Article 166, paragraph 7, of the Code and Article 16 of the Authority's Regulation No. 1/2019, should be applied, given the high number of subjects involved and the type of personal data subject to unlawful processing.

Finally, it is noted that the conditions referred to in Article 17 of the Authority's Regulation No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

****FOR ALL THE ABOVE REASONS, THE AUTHORITY****

declares the unlawfulness of the processing of personal data carried out by ASL Napoli 3 Sud, for the violation of Articles 5, paragraph 1, letter f), 25, and 32 of the Regulation, as stated in the reasoning.

****ORDERS****

pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, ASL Napoli 3 Sud, with registered office in Torre del Greco, Via Marconi, 66, Tax Code and VAT Number 06322711216, in the person of the legal representative pro tempore, to pay the sum of €30,000.00 (thirty thousand) as an administrative monetary sanction for the violation indicated in this provision; it is noted that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction.

****ORDERS****

the aforementioned ASL Napoli 3 Sud, in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €30,000.00 (thirty thousand) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of subsequent enforcement acts in accordance with Article 27 of Law No. 689/1981.

****DISPOSES****

pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the Authority's website and considers that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to file a judicial appeal before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, September 28, 2023

****THE PRESIDENT****

Stanzione

****THE RAPPORTEUR****

Ghiglia

****THE SECRETARY GENERAL****

Mattei